

Threat Modeling

IPB Lost and Found IPB - Kelompok 03

Nama	NIM	Kelas
Nisa Amelia	G6401231022	K1
Rahma Dhana	G6401231023	K1
Kasyifa Naila	G6401231139	K1

Mata Kuliah KOM1315 – Keamanan Informasi
Departemen Ilmu Komputer, IPB University

I. Pendahuluan

A. Latar Belakang

Dokumen ini menjelaskan hasil analisis ancaman (threat modelling) terhadap Sistem Lost and Found IPB University menggunakan kerangka kerja STRIDE. Analisis dilakukan untuk mengidentifikasi potensi ancaman keamanan, aset yang berisiko, serta mitigasi yang diterapkan atau direncanakan pada arsitektur sistem.

Sistem Lost and Found IPB University merupakan platform berbasis web yang memungkinkan mahasiswa dan civitas akademika IPB untuk melaporkan barang hilang maupun barang yang ditemukan di lingkungan kampus. Sistem ini mengelola data sensitif berupa identitas pengguna, informasi kontak, foto barang, dan riwayat laporan tiket sehingga memerlukan perlindungan keamanan yang komprehensif.

STRIDE adalah akronim dari: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, dan Elevation of Privilege.

Skala Penilaian Kemungkinan dan Dampak: T = Tinggi, S = Sedang, R = Rendah, ST = Sangat Tinggi

B. Aset yang Dilindungi

Berikut merupakan aset-aset penting yang diidentifikasi dalam Sistem Lost and Found IPB University yang perlu dilindungi dari ancaman keamanan:

Kategori Aset	Aset	Keterangan
Data Pengguna	Email, Username, Password (hashed)	Data identitas mahasiswa dan admin yang tersimpan di database.
Data Barang	Data barang hilang, deskripsi, lokasi, kategori	Informasi laporan barang yang dibuat oleh pengguna.

Kategori Aset	Aset	Keterangan
Data Media	Foto barang hilang/temuan	Berkas gambar yang diunggah sebagai bukti visual laporan.
Data Laporan	Riwayat tiket / laporan barang	Histori pengajuan tiket beserta statusnya.
Data Kontak	Informasi kontak pelapor	Data kontak pengguna yang bersifat sensitif pada tiket laporan.
Secret Key	AES_SECRET_KEY, Session Secret	Kunci rahasia di konfigurasi server untuk enkripsi dan sesi.

II. Analisis Ancaman STRIDE

Tabel berikut merangkum seluruh ancaman yang diidentifikasi berdasarkan kerangka STRIDE, beserta tingkat kemungkinan (Likelihood), dampak (Impact), dan mitigasi konkrit yang diterapkan atau direncanakan.

ID	Kategori	Ancaman	Aset Terdampak	Likelihood	Impact	Risk	Mitigasi
S-02	Spoofing	Penyerang mengambil alih session login aktif milik pengguna (session hijacking) melalui XSS atau packet sniffing.	Session Token, Data Akun	S	T	Tinggi	Flag HttpOnly, HTTPS, validasi IP/User-Agent, session timeout otomatis.
T-01	Tampering	Mahasiswa memanipulasi request HTTP untuk mengubah status tiket orang lain atau data yang bukan miliknya.	Tiket / Laporan Barang	S	S	Sedang	Validasi kepemilikan tiket berdasarkan user_id sesi aktif sebelum setiap operasi update.
T-02	Tampering	Manipulasi data input form untuk menyisipkan skrip berbahaya (XSS) atau karakter SQL ke dalam sistem.	Database, Tampilan UI	T	T	Sangat Tinggi	Sanitasi dan validasi semua input, Content Security Policy.
R-02	Repudiation	Mahasiswa menyangkal telah membuat atau mengubah laporan tiket tertentu dalam sistem.	Tiket / Laporan	R	S	Rendah	Setiap tiket terikat ke user_id + timestamp pembuatan yang tidak dapat diubah pengguna.
I-01	Info Disclosure	Kebocoran data password dalam bentuk plaintext akibat SQL Injection pada endpoint login atau pencarian.	Password Pengguna, DB	S	ST	Sangat Tinggi	ORM/Prepared Statement, bcrypt hash pada semua password, enkripsi AES-GCM data at rest.

ID	Kategori	Ancaman	Aset Terdampak	Likelihood	Impact	Risk	Mitigasi
I-03	Info Disclosure	Kunci rahasia (AES_SECRET_KEY, session secret) terekspos karena tidak sengaja masuk ke repository publik.	Seluruh sistem	R	ST	Sedang	Isolasi kunci di file .env, wajib didaftarkan di .gitignore, rotasi kunci berkala.

III. Tabel Resiko dan Mitigasi

Tabel berikut merangkum semua ancaman yang teridentifikasi beserta level risiko dan urutan prioritas penanganan berdasarkan hasil analisis STRIDE.

Ancaman	Komponen Terancam	Probabilitas	Dampak	Level Risiko	Prioritas Mitigasi
SQL Injection	Database Sistem	Sedang	Sangat Tinggi	Sangat Tinggi	Prioritas 1
Session Hijacking	Session Login	Sedang	Tinggi	Tinggi	Prioritas 2
XSS / Input Injection	Database, UI	Tinggi	Tinggi	Sangat Tinggi	Prioritas 1
Unauthorized Access	Endpoint Admin	Sedang	Tinggi	Tinggi	Prioritas 2
Data Kebocoran DB	Data Pengguna	Sedang	Sangat Tinggi	Sangat Tinggi	Prioritas 1
Denial of Service	Server, Endpoint	Tinggi	Sedang	Sedang	Prioritas 3
Repudiation Admin	Log Tiket	Sedang	Sedang	Sedang	Prioritas 3

IV. Arsitektur Keamanan Sistem

Berdasarkan hasil threat modelling, arsitektur keamanan sistem dirancang dengan tiga komponen utama, yaitu Authentication (Autentikasi Pengguna), Data Protection (Perlindungan Data), dan Database Security (Keamanan Basis Data).

A. Authentication (Autentikasi Pengguna)

Sistem autentikasi diimplementasikan dengan mekanisme login berbasis username dan password. Password pengguna tidak pernah disimpan dalam bentuk plain text, melainkan di-hash menggunakan algoritma bcrypt dengan salt acak sebelum disimpan ke basis data. Sistem juga menerapkan session management untuk menjaga status login pengguna selama sesi aktif. Penyimpanan password dilakukan menggunakan hashing bcrypt sehingga password yang tersimpan di basis data tetap terlindungi meskipun terjadi kebocoran data.

B. Data Protection (Perlindungan Data)

Data sensitif pengguna dienkripsi menggunakan algoritma AES-GCM sebelum disimpan ke basis data. Selain itu, validasi input diterapkan pada seluruh formulir untuk mencegah data berbahaya masuk ke dalam sistem. Komunikasi antara klien dan server menggunakan HTTPS untuk melindungi data selama proses transmisi. Enkripsi data saat penyimpanan (data at rest) menggunakan AES-GCM 256-bit untuk melindungi data identitas pelapor, informasi kontak, dan deskripsi barang. Pada proses ini juga dihasilkan Authentication Tag untuk memastikan integritas data. Sementara itu, enkripsi data saat transmisi (data in transit) dilakukan menggunakan HTTPS untuk seluruh komunikasi antara klien dan server. Seluruh input pengguna juga disanitasi dan divalidasi sebelum diproses oleh sistem.

C. Database Security (Keamanan Basis Data)

Keamanan basis data diterapkan untuk melindungi data dari manipulasi dan akses yang tidak sah. Seluruh query basis data menggunakan Prepared Statement atau ORM (Object-Relational Mapping) untuk mencegah serangan SQL Injection. Pencegahan SQL Injection dilakukan melalui penggunaan Prepared Statement atau ORM secara konsisten pada seluruh operasi basis data. Selain itu, sistem menerapkan prinsip least privilege, yaitu akun basis data yang digunakan aplikasi hanya diberikan hak akses minimum yang diperlukan.

V. Alur Logika Keamanan Sistem

Alur logika keamanan sistem menggambarkan tahapan keamanan yang diterapkan pada setiap interaksi pengguna dengan sistem, mulai dari proses login hingga penyimpanan data tiket laporan.

Tahap pertama adalah autentikasi (Authentication). Pengguna membuka aplikasi dan memasukkan username serta password. Sistem memvalidasi kredensial dengan mencocokkan hash password yang dimasukkan pengguna dengan hash yang tersimpan pada basis data. Apabila kredensial valid, proses login berhasil dan sesi pengguna dimulai. Sebaliknya, jika kredensial tidak valid, sistem akan menampilkan pesan kesalahan dan mencatat percobaan login yang gagal sebagai bagian dari mekanisme rate limiting.

Tahap kedua adalah otorisasi (Authorization). Setelah proses login berhasil, sistem memeriksa peran (role) pengguna. Pengguna dengan peran mahasiswa dapat membuat tiket laporan barang hilang atau ditemukan serta melacak status laporan yang telah dibuat. Sementara itu, pengguna dengan peran admin memiliki hak akses tambahan untuk melakukan verifikasi tiket dan mengelola sistem.

Tahap ketiga adalah validasi input. Ketika pengguna membuat tiket laporan barang, seluruh data yang dimasukkan akan melalui proses validasi dan sanitasi sebelum diproses oleh sistem. Validasi dilakukan dengan memeriksa format data, panjang karakter, serta karakter yang diperbolehkan guna mencegah berbagai bentuk serangan injection.

Tahap keempat adalah enkripsi data menggunakan AES-GCM. Setelah data dinyatakan valid, informasi sensitif yang terdapat pada tiket laporan akan dienkripsi menggunakan algoritma AES-GCM sebelum disimpan ke basis data. Authentication Tag juga dihasilkan untuk memastikan integritas data dan mendeteksi adanya perubahan yang tidak sah.

Tahap kelima adalah penyimpanan terenkripsi. Data yang telah dienkripsi disimpan ke dalam basis data dalam bentuk ciphertext. Kunci enkripsi yang digunakan disimpan secara terpisah dari basis data utama untuk meningkatkan keamanan.

Tahap keenam adalah pemrosesan admin dan notifikasi. Admin melakukan verifikasi terhadap tiket laporan yang masuk. Berdasarkan hasil verifikasi, status barang dapat diperbarui. Jika barang berhasil ditemukan, sistem akan mengirimkan notifikasi kepada pelapor terkait.